

| Term          | Full Form                                      | Meaning in this workbook                                                                                                                                                  |
|---------------|------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| SoA           | Statement of Applicability                     | ISO/IEC 27001 document recording whether each Annex A control applies, and why.                                                                                           |
| POA / POA&M   | Plan of Action & Milestones                    | Remediation item tracked in the Gap Analysis & Remediation Roadmap (e.g. POA-01). See 'Risk/POA Link' column.                                                             |
| Annex A       | ISO/IEC 27001:2022 Annex A                     | The standard's catalogue of 93 information security controls, grouped into 4 themes.                                                                                      |
| Control ID    | —                                              | Annex A control number, e.g. 5.1, 8.5, 7.9. First digit/theme: 5.x = Organizational, 6.x = People, 7.x = Physical, 8.x = Technological.                                   |
| Theme         | —                                              | Which of the 4 Annex A control groups a control belongs to (Organizational / People / Physical / Technological).                                                          |
| SoA Status    | —                                              | Yes = control substantively implemented. Partial = informal/incomplete. No = not currently addressed.                                                                     |
| Audit Result  | —                                              | Pass / Fail / Observation — outcome of the Internal Audit Checklist for the ~15 controls that were actually sampled and tested. Blank = not included in the audit sample. |
| Risk/POA Link | —                                              | Cross-reference to a specific risk (Risk Register) or remediation item (POA&M) tied to this control, where one exists.                                                    |
| MFA           | Multi-Factor Authentication                    | Referenced in several control notes (e.g. VPN gateway finding).                                                                                                           |
| PAM           | Privileged Access Management                   | A recommended solution for managing shared/admin account risk (see POA-03).                                                                                               |
| EDR           | Endpoint Detection & Response                  | Endpoint security tooling referenced under control 8.7.                                                                                                                   |
| SIEM          | Security Information & Event Management        | Logging/monitoring platform referenced under controls 8.15 / 8.16 (Wazuh, in this case study).                                                                            |
| VAPT          | Vulnerability Assessment & Penetration Testing | Referenced under control 8.8.                                                                                                                                             |
| CI/CD         | Continuous Integration / Continuous Deployment | Software delivery pipeline referenced in the Risk Register and control 5.21.                                                                                              |
| ISMS          | Information Security Management System         | The overall system of policy, risk assessment, controls, and audit that these documents collectively form.                                                                |

| Control ID | Title                                                             | Theme          | SoA Status | Audit Result | Risk/POA Link | Owner            | Target Date    | Notes |
|------------|-------------------------------------------------------------------|----------------|------------|--------------|---------------|------------------|----------------|-------|
| 5.1        | Policies for information security                                 | Organizational | Yes        | Pass         |               |                  |                |       |
| 5.2        | Information security roles and responsibilities                   | Organizational | Yes        |              |               |                  |                |       |
| 5.3        | Segregation of duties                                             | Organizational | Partial    |              |               | IT Security Lead | TBD next cycle |       |
| 5.4        | Management responsibilities                                       | Organizational | Yes        |              |               |                  |                |       |
| 5.5        | Contact with authorities                                          | Organizational | Partial    |              |               | IT Security Lead | TBD next cycle |       |
| 5.6        | Contact with special interest groups                              | Organizational | No         |              |               | IT Security Lead | TBD next cycle |       |
| 5.7        | Threat intelligence                                               | Organizational | Partial    |              |               | IT Security Lead | TBD next cycle |       |
| 5.8        | Information security in project management                        | Organizational | Partial    |              |               | IT Security Lead | TBD next cycle |       |
| 5.9        | Inventory of information and other associated assets              | Organizational | Yes        |              |               |                  |                |       |
| 5.10       | Acceptable use of information and other associated assets         | Organizational | Partial    |              |               | IT Security Lead | TBD next cycle |       |
| 5.11       | Return of assets                                                  | Organizational | Yes        |              |               |                  |                |       |
| 5.12       | Classification of information                                     | Organizational | No         |              |               | IT Security Lead | 90 days        |       |
| 5.13       | Labelling of information                                          | Organizational | No         |              |               | IT Security Lead | 90 days        |       |
| 5.14       | Information transfer                                              | Organizational | Partial    |              |               | IT Security Lead | TBD next cycle |       |
| 5.15       | Access control                                                    | Organizational | Yes        |              |               |                  |                |       |
| 5.16       | Identity management                                               | Organizational | Yes        |              |               |                  |                |       |
| 5.17       | Authentication information                                        | Organizational | Yes        |              |               |                  |                |       |
| 5.18       | Access rights                                                     | Organizational | Yes        | Pass         |               |                  |                |       |
| 5.19       | Information security in supplier relationships                    | Organizational | No         |              |               | Procurement      | 90 days        |       |
| 5.20       | Addressing information security within supplier agreements        | Organizational | No         |              |               | Procurement      | 90 days        |       |
| 5.21       | Managing information security in the ICT supply chain             | Organizational | Partial    |              |               | IT Security Lead | TBD next cycle |       |
| 5.22       | Monitoring, review and change management of supplier services     | Organizational | No         |              |               | Procurement      | 90 days        |       |
| 5.23       | Information security for use of cloud services                    | Organizational | Partial    |              |               | IT Security Lead | TBD next cycle |       |
| 5.24       | Information security incident management planning and preparation | Organizational | Yes        | Pass         |               |                  |                |       |
| 5.25       | Assessment and decision on information security events            | Organizational | Yes        |              |               |                  |                |       |
| 5.26       | Response to information security incidents                        | Organizational | Yes        |              |               |                  |                |       |
| 5.27       | Learning from information security incidents                      | Organizational | Yes        |              |               |                  |                |       |
| 5.28       | Collection of evidence                                            | Organizational | Partial    |              |               | IT Security Lead | TBD next cycle |       |
| 5.29       | Information security during disruption                            | Organizational | No         |              |               | IT Security Lead | TBD next cycle |       |
| 5.30       | ICT readiness for business continuity                             | Organizational | No         |              |               | CTO              | 90 days        |       |
| 5.31       | Legal, statutory, regulatory and contractual requirements         | Organizational | Partial    |              |               | IT Security Lead | TBD next cycle |       |
| 5.32       | Intellectual property rights                                      | Organizational | Partial    |              |               | IT Security Lead | TBD next cycle |       |
| 5.33       | Protection of records                                             | Organizational | Partial    |              |               | IT Security Lead | TBD next cycle |       |

| Control ID | Title                                                                  | Theme          | SoA Status | Audit Result | Risk/POA Link | Owner            | Target Date    | Notes            |
|------------|------------------------------------------------------------------------|----------------|------------|--------------|---------------|------------------|----------------|------------------|
| 5.34       | Privacy and protection of PII                                          | Organizational | Partial    |              |               | IT Security Lead | TBD next cycle |                  |
| 5.35       | Independent review of information security                             | Organizational | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 5.36       | Compliance with policies, rules and standards for information security | Organizational | Yes        | Observation  | POA-12        | See POA&M        | See POA&M      | Linked to POA-12 |
| 5.37       | Documented operating procedures                                        | Organizational | Partial    |              |               | IT Security Lead | TBD next cycle |                  |
| 6.1        | Screening                                                              | People         | No         |              |               | HR               | 90 days        |                  |
| 6.2        | Terms and conditions of employment                                     | People         | Partial    |              |               | IT Security Lead | TBD next cycle |                  |
| 6.3        | Information security awareness, education and training                 | People         | Partial    | Observation  | POA-10        | See POA&M        | See POA&M      | Linked to POA-10 |
| 6.4        | Disciplinary process                                                   | People         | No         |              |               | HR               | 120 days       |                  |
| 6.5        | Responsibilities after termination or change of employment             | People         | Yes        |              |               |                  |                |                  |
| 6.6        | Confidentiality or non-disclosure agreements                           | People         | Partial    |              |               | IT Security Lead | TBD next cycle |                  |
| 6.7        | Remote working                                                         | People         | Partial    |              |               | IT Security Lead | TBD next cycle |                  |
| 6.8        | Information security event reporting                                   | People         | Yes        |              |               |                  |                |                  |
| 7.1        | Physical security perimeters                                           | Physical       | Partial    |              |               | IT Security Lead | TBD next cycle |                  |
| 7.2        | Physical entry                                                         | Physical       | Partial    |              |               | IT Security Lead | TBD next cycle |                  |
| 7.3        | Securing offices, rooms and facilities                                 | Physical       | Partial    |              |               | IT Security Lead | TBD next cycle |                  |
| 7.4        | Physical security monitoring                                           | Physical       | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 7.5        | Protecting against physical and environmental threats                  | Physical       | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 7.6        | Working in secure areas                                                | Physical       | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 7.7        | Clear desk and clear screen                                            | Physical       | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 7.8        | Equipment siting and protection                                        | Physical       | Partial    |              |               | IT Security Lead | TBD next cycle |                  |
| 7.9        | Security of assets off-premises                                        | Physical       | Yes        |              |               |                  |                |                  |
| 7.10       | Storage media                                                          | Physical       | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 7.11       | Supporting utilities                                                   | Physical       | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 7.12       | Cabling security                                                       | Physical       | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 7.13       | Equipment maintenance                                                  | Physical       | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 7.14       | Secure disposal or re-use of equipment                                 | Physical       | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 8.1        | User end point devices                                                 | Technological  | Yes        |              |               |                  |                |                  |
| 8.2        | Privileged access rights                                               | Technological  | Yes        | Fail         | POA-03        | See POA&M        | See POA&M      | Linked to POA-03 |
| 8.3        | Information access restriction                                         | Technological  | Yes        |              |               |                  |                |                  |
| 8.4        | Access to source code                                                  | Technological  | Yes        | Fail         | POA-02        | See POA&M        | See POA&M      | Linked to POA-02 |
| 8.5        | Secure authentication                                                  | Technological  | Yes        | Fail         | POA-01        | See POA&M        | See POA&M      | Linked to POA-01 |
| 8.6        | Capacity management                                                    | Technological  | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 8.7        | Protection against malware                                             | Technological  | Yes        | Pass         |               |                  |                |                  |
| 8.8        | Management of technical vulnerabilities                                | Technological  | Yes        | Observation  | POA-09        | See POA&M        | See POA&M      | Linked to POA-09 |

| Control ID | Title                                                       | Theme         | SoA Status | Audit Result | Risk/POA Link | Owner            | Target Date    | Notes            |
|------------|-------------------------------------------------------------|---------------|------------|--------------|---------------|------------------|----------------|------------------|
| 8.9        | Configuration management                                    | Technological | Partial    |              |               | IT Security Lead | TBD next cycle |                  |
| 8.10       | Information deletion                                        | Technological | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 8.11       | Data masking                                                | Technological | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 8.12       | Data leakage prevention                                     | Technological | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 8.13       | Information backup                                          | Technological | Yes        | Fail         | POA-04        | See POA&M        | See POA&M      | Linked to POA-04 |
| 8.14       | Redundancy of information processing facilities             | Technological | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 8.15       | Logging                                                     | Technological | Yes        | Pass         |               |                  |                |                  |
| 8.16       | Monitoring activities                                       | Technological | Yes        |              |               |                  |                |                  |
| 8.17       | Clock synchronisation                                       | Technological | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 8.18       | Use of privileged utility programs                          | Technological | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 8.19       | Installation of software on operational systems             | Technological | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 8.20       | Networks security                                           | Technological | Yes        | Pass         |               |                  |                |                  |
| 8.21       | Security of network services                                | Technological | Partial    |              |               | IT Security Lead | TBD next cycle |                  |
| 8.22       | Segregation of networks                                     | Technological | Partial    |              |               | IT Security Lead | TBD next cycle |                  |
| 8.23       | Web filtering                                               | Technological | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 8.24       | Use of cryptography                                         | Technological | Yes        | Pass         |               |                  |                |                  |
| 8.25       | Secure development life cycle                               | Technological | Partial    |              |               | IT Security Lead | TBD next cycle |                  |
| 8.26       | Application security requirements                           | Technological | Partial    |              |               | IT Security Lead | TBD next cycle |                  |
| 8.27       | Secure system architecture and engineering principles       | Technological | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 8.28       | Secure coding                                               | Technological | Yes        |              |               |                  |                |                  |
| 8.29       | Security testing in development and acceptance              | Technological | Yes        |              |               |                  |                |                  |
| 8.30       | Outsourced development                                      | Technological | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 8.31       | Separation of development, test and production environments | Technological | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 8.32       | Change management                                           | Technological | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 8.33       | Test information                                            | Technological | No         |              |               | IT Security Lead | TBD next cycle |                  |
| 8.34       | Protection of information systems during audit testing      | Technological | Partial    |              |               | IT Security Lead | TBD next cycle |                  |

| Metric                        | Count |
|-------------------------------|-------|
| Total Annex A Controls        | 93    |
| SoA — Yes                     | 31    |
| SoA — Partial                 | 28    |
| SoA — No                      | 34    |
| Controls Audited (Cycle 1)    | 14    |
| Audit — Pass                  | 7     |
| Audit — Fail (Non-conformity) | 4     |
| Audit — Observation           | 3     |
| Open POA&M Items Linked       | 7     |